DBMS 접근 관리

보안 점검 항목 D-11 ~ D-15

데이터베이스 시스템의 안전한 운영을 위한 접근 관리 보안 점검 항목입니다. 시스템 테이블 접근 제한, 리스너 비밀번호 설정, 불필요한 데이터 소스 제거, 주요 파일 권한 관리 등 핵심 보안 통제 사항을 다룹니다.

DBMS 보안 | 접근 관리 | D-11 ~ D-15

D-11 · 위험도: 상

시스템 테이블 접근 제한

점검 목적

일반 사용자 계정 유출 시 발생할 수 있는 비인가자의 시스템 테이블 접근 위험을 차단하기 위함

보안 위협

접근 제한 미설정 시 Object, 사용자, 테이블·뷰, 작업 내역 등 시스템 테이블 정보가 누출될 수 있음

판단 기준

✅ 양호

시스템 테이블에 **DBA만** 접근 가능하도록 설정된 경우

❌ 취약

DBA 외 **일반 사용자 계정**이 접근 가능하도록 설정된 경우

점검 대상

Oracle DB, MSSQL, MySQL, Altibase, Tibero, PostgreSQL 등

D-11 · 조치 사례

시스템 테이블 접근 제한 — 조치 방법

Oracle DB / Tibero

DBA만 접근 가능한 테이블 권한 확인 후 불필요한 권한 회수

```
SQL> REVOKE <권한> ON <테이블> FROM user;
```

MSSQL

PUBLIC·GUEST 등 비인가 계정의 접근 권한 제거. 시스템 테이블 접근은 stored procedure 또는 information_schema views를 통해서만 허용

```
REVOKE <권한> ON <테이블> FROM [PUBLIC];
```

MySQL

계정 권한 확인 후 필요한 DB·테이블에만 최소 권한 적용

```
SHOW GRANTS FOR <계정명>;
GRANT <권한> ON <DB>.<테이블> TO '계정@호스트';
```

Altibase / PostgreSQL

Altibase: sys_tables_ 조회 후 불필요 계정 접근 해제
PostgreSQL: role_table_grants 조회 후 일반 사용자 권한 REVOKE

```
REVOKE [all,...] ON all tables
IN schema '스키마명' FROM '계정명';
```

D-12 · 위험도: 상

Oracle 리스너 비밀번호 설정

점검 목적 및 보안 위험

Listener Owner는 DBA가 아니더라도 Listener를 shutdown하거나 DB 서버에 임의 파일을 생성할 수 있으며, 원격에서 LSNRCTL로 listener.ora 변경이 가능합니다. 비밀번호 미설정 시 **DoS, 정보 획득, 프로세스 중지** 위험이 존재합니다.

판단 기준

- **양호**: Listener 비밀번호가 설정된 경우
- **취약**: Listener 비밀번호가 설정되지 않은 경우

⚠ Oracle 12c Release 2 이후 버전은 Listener 비밀번호 설정을 지원하지 않으므로 해당 없음

조치 절차

01

비밀번호 변경

`LSNRCTL> change_password` 명령으로 신규 비밀번호 설정 후 `set password` 및 `save_config` 실행

02

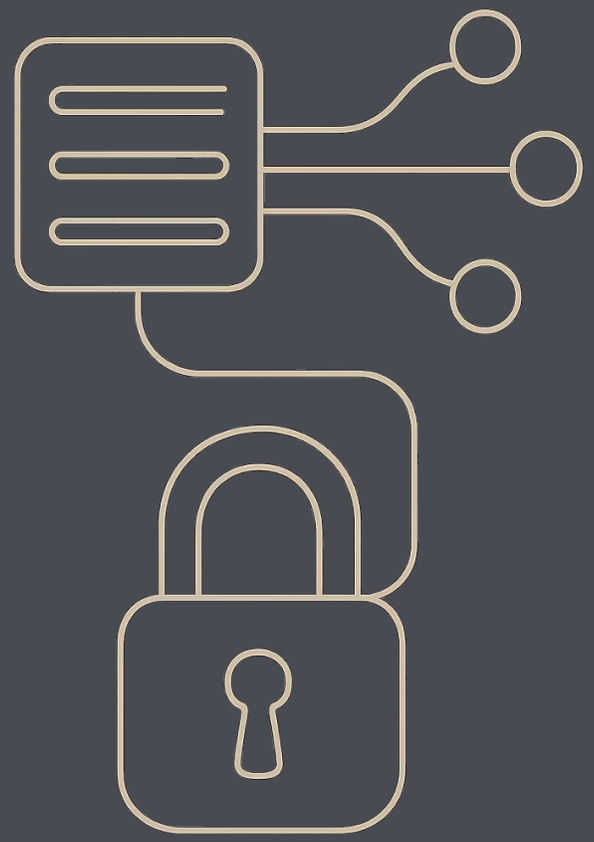
listener.ora 파라미터 추가

`PASSWORDS_<listener_name>` 및 `ADMIN_RESTRICTIONS_<listener_name> = ON` 옵션 추가

03

Listener 재시작 및 상태 확인

`lsnrctl stop` → `lsnrctl start` → `lsnrctl status` 순서로 재시작 및 정상 동작 확인



D-13 · 위험도: 중

불필요한 ODBC/OLE-DB 제거

불필요한 데이터 소스 및 드라이버를 제거하여 비인가자의 데이터베이스 접속 및 주요 정보 유출을 차단합니다. 샘플 응용 프로그램이 설치한 ODBC 데이터 소스나 불필요한 드라이버는 ODBC 데이터 소스 관리자 도구로 제거해야 합니다.

판단 기준

✅ 양호

불필요한 ODBC/OLE-DB가 **설치되지 않은** 경우

❌ 취약

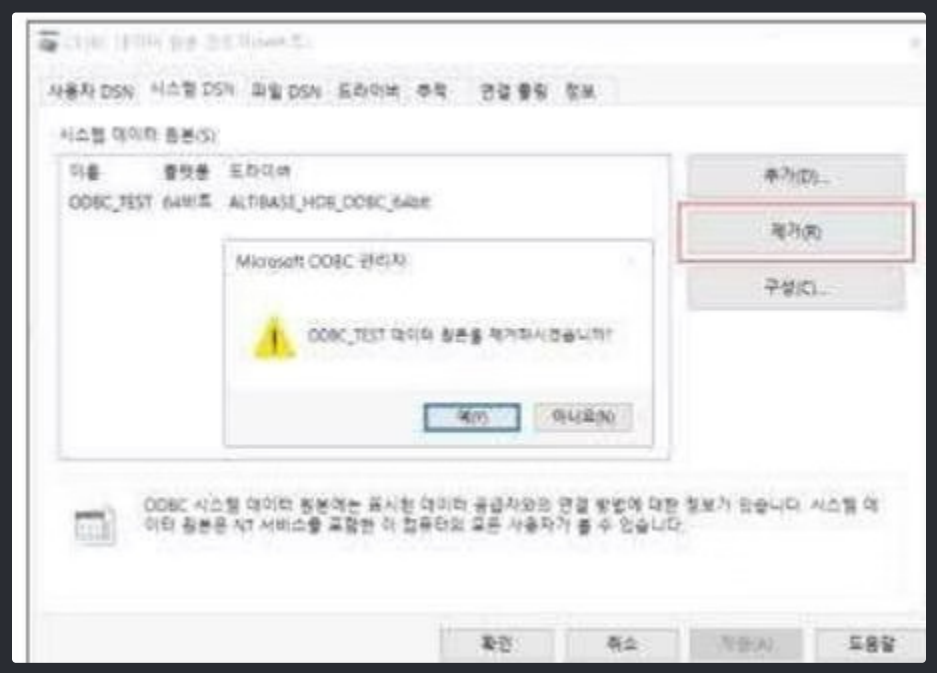
불필요한 ODBC/OLE-DB가 **설치된** 경우

점검 대상

Windows OS (NT, 2000, 2003, 2008, 2012, 2016, 2019, 2022)

조치 경로 (Windows 2019/2022)

시작 → 제어판 → 시스템 및 보안 → 관리 도구 → **ODBC 데이터 원본 관리자** → 시스템 DSN → 해당 드라이버 선택 후 제거



D-14 · 위험도: 중

주요 파일 접근 권한 설정

데이터베이스 주요 파일(orapw.ora, listener.ora, init.ora, redo 파일, 설정 파일 등)에 대해 관리자를 제외한 일반 사용자의 수정 권한을 제거하여 비인가자에 의한 변경·삭제 및 정보 유출을 방지합니다.

Oracle DB (Unix)

- `$ORACLE_HOME/bin/oracle`: 755
- `listener.ora`, `sqlnet.ora`: 755
- `tnsnames.ora`: 644
- `init.ora`, `init<SID>.ora`: 640

MySQL

- Unix: `my.cnf` 권한을 **600 또는 640**으로 설정
- Windows: Administrators, SYSTEM, Owner에게만 권한 부여, 기타 그룹 제거

PostgreSQL (Unix)

- `postgresql.conf`: 640 이하
- `pg_hba.conf`, `pg_ident.conf`: 640 이하
- `.psql_history`: 600 이하
- Log 파일(`pg_log`): 640 이하

Cubrid

- `cubrid.conf` 권한 확인 후 **600 또는 640**으로 설정
- `chmod 640 cubrid.conf`

D-14 · 조치 상세

Oracle DB 주요 파일 권한 점검 명령어

Step 1) 디렉터리·파일 권한 점검 및 변경

```
$ORACLE_HOME/bin/oracle          (755)
$ORACLE_HOME/network/admin/      (755)
  listener.ora, sqlnet.ora       (755)
  tnsnames.ora, protocol.ora     (644)
$ORACLE_HOME/dbs/init.ora        (640)
$ORACLE_HOME/dbs/init<SID>.ora   (640)

# chmod <적용 권한> <파일명>
```

Step 2) redo·데이터 파일 위치 확인 (SQL*Plus)

```
SQL> SELECT value FROM v$parameter
     WHERE name='spfile';
SQL> SELECT 'Control Files: '||value
     FROM v$parameter
     WHERE name='control_files';
SQL> SELECT 'Logfile: '||member
     FROM v$logfile;
SQL> SELECT 'Datafile: '||name
     FROM v$datafile;

# chmod <적용 권한> <파일명>
```

ⓘ Windows OS의 경우 패스워드 파일(orapw)의 접근 권한을 Administrators, SYSTEM group, Owner group, Oracle service account, DBA에게만 부여하고 기타 그룹은 제거합니다.

D-15 · 위험도: 하

Oracle 리스너 로그·Trace 파일 변경 제한

점검 목적 및 보안 위험

비인가자가 LSNRCTL 유틸리티로 Listener에 직접 접근할 경우 모든 파라미터를 변경할 수 있으며, **trace 파일 및 Listener 로그 파일 변조** 위험이 존재합니다. 설정 파일 권한을 관리자로 제한하고 파라미터 변경 방지 옵션을 설정해야 합니다.

판단 기준

✅ 양호

Listener 설정 파일 권한이 관리자로 설정되어 있으며, 파라미터 변경 불가 옵션이 설정된 경우

❌ 취약

Listener 설정 파일 권한이 일반 사용자로 설정되어 있고, 파라미터 변경 방지 옵션이 미설정된 경우

조치 절차 (Oracle DB)

01

파일 권한 확인

`$ORACLE_HOME/network/admin` 디렉터리 권한 확인 (Unix: `ls -a` / Windows: 파일 속성)

02

Listener 상태 확인

`LSNRCTL> status ListenerName` 명령으로 listener.ora 파일 확인

03

ADMIN_RESTRICTIONS 설정

listener.ora 파일에 `ADMIN_RESTRICTIONS_<listener_name> = ON` 설정 확인 및 적용

점검 항목 종합 요약

항목	점검 내용	위험도	대상	핵심 조치
D-11	시스템 테이블 접근 제한	상	Oracle, MSSQL, MySQL, Altibase, Tibero, PostgreSQL	DBA 외 일반 계정 접근 권한 REVOKE
D-12	리스너 비밀번호 설정	상	Oracle DB	LSNRCTL change_password 및 ADMIN_RESTRICTIONS=ON
D-13	불필요한 ODBC/OLE-DB 제거	중	Windows OS	ODBC 데이터 원본 관리자에서 미사용 소스 제거
D-14	주요 파일 접근 권한 설정	중	Oracle, MySQL, PostgreSQL, Cubrid	설정 파일 권한 640 이하, 관리자 외 수정 권한 제거
D-15	리스너 로그·Trace 변경 제한	하	Oracle DB	network/admin 권한 제한 및 ADMIN_RESTRICTIONS=ON

ⓘ 조치 시 영향: D-11은 일반 계정의 시스템 테이블 접근 불가. D-12~D-15는 일반적인 경우 서비스 영향 없음.

핵심 보안 원칙 및 권고사항

최소 권한 원칙

모든 계정에 업무 수행에 필요한 최소한의 권한만 부여하고, 불필요한 권한은 즉시 회수합니다.

인증 강화

Listener 등 주요 컴포넌트에 반드시 비밀번호를 설정하고, 비인가자의 원격 접근을 차단합니다.

파일 권한 관리

주요 설정 파일은 640 이하로 권한을 제한하고, 관리자 외 수정 권한을 제거하여 무결성을 유지합니다.

불필요 요소 제거

미사용 ODBC/OLE-DB 데이터 소스와 드라이버를 정기적으로 점검하고 제거하여 공격 표면을 최소화합니다.